Cloud Infrastructure Security Standard

Policy ID: STD-CLD-003 | Version 1.0 | Classification: Internal

Policy Owner	CISO / Head of Cloud Platform	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This standard defines the mandatory security baseline for public cloud, private cloud, hosted infrastructure, platform-as-a-service, serverless, container, and infrastructure-as-code environments. Its objective is to ensure cloud systems are securely designed, hardened, observable, recoverable, and governed through centrally enforceable guardrails.

2. Scope

This standard applies to all enterprise cloud tenants, subscriptions, accounts, projects, virtual networks, compute instances, managed databases, storage, container clusters, serverless functions, secrets stores, CI/CD identities, marketplace products, and cloud management planes, including development, test, staging, production, disaster recovery, and sandbox environments.

3. Governance, Accountability, and Roles

Cloud Platform Team. Provides landing zones, guardrails, identity federation, central logging, network patterns, and approved services.

Workload Owners. Classify workloads, implement required controls, patch, monitor, backup, and remediate findings.

Security. Defines baselines, continuously evaluates posture, and approves high-risk deviations.

FinOps / Asset Governance. Maintains account ownership, lifecycle, tagging, and cost/accountability data.

4. Policy Rules and Mandatory Guidelines

- All cloud resources MUST reside in enterprise-managed organizations/tenants and approved accounts. Shadow cloud accounts purchased on personal or team credit cards are Strictly Prohibited.
- Production and non-production workloads MUST be separated using distinct accounts/subscriptions/projects or equivalent strong administrative boundaries. Production secrets MUST NOT be available to non-production identities.
- Human administrative access MUST use enterprise federation, phishing-resistant MFA where supported, and centralized lifecycle management. Long-lived standalone cloud IAM users are prohibited except break-glass identities approved by Security.
- Root, owner, or tenant-global administrator accounts MUST NOT be used for routine operations. Emergency credentials MUST be vaulted, monitored, tested, and subject to post-use review.
- Internet exposure is deny-by-default. Any public IP, public load balancer, public bucket, public database, or public management endpoint requires documented service need and security controls appropriate to the exposure.

- Security groups, network security lists, and firewalls MUST restrict inbound and outbound traffic to necessary ports, protocols, sources, and destinations. 0.0.0.0/0 administrative access to SSH, RDP, database, Kubernetes API, or management ports is Strictly Prohibited.
- Cloud storage containing non-public data MUST block anonymous/public access. Access policies MUST use least privilege and must not rely on obscure object URLs as a security mechanism.
- All resources MUST carry required ownership, environment, data-classification, cost-center, and lifecycle tags/labels. Untagged resources may be automatically quarantined or deleted after notice according to platform policy.
- Infrastructure changes to production MUST be made through approved Infrastructure as Code (IaC) and reviewed change pipelines except documented emergency procedures. Manual console changes that create configuration drift MUST be reconciled promptly.
- Cloud services that cannot provide required logging, encryption, regional, identity, backup, or contractual controls MUST NOT host regulated or sensitive workloads.

5. Technical and Coding Constraints

- IaC templates MUST be scanned pre-merge using approved tools such as Checkov, tfsec, Terrascan, Trivy, cloud-native policy engines, or an enterprise equivalent. Critical policy violations MUST block deployment.
- Terraform/OpenTofu state, deployment templates, CI variables, and cloud-init/user-data MUST NOT contain plaintext passwords, API keys, private keys, or tokens. Secrets MUST be referenced from approved secret-management services.
- Cloud audit logs for control-plane and data-plane activity where available MUST be enabled, centralized, tamper-resistant, and retained according to the security logging standard. Disabling audit logging is prohibited.
- Storage and managed database encryption at rest MUST be enabled using provider-managed or customer-managed keys based on data classification. Highly sensitive workloads SHOULD use customer-managed keys with separation of key administration from data administration.
- Metadata services on compute instances MUST use hardened versions and hop/session protections where supported. Legacy unauthenticated metadata access SHOULD be disabled.
- Golden images and container base images MUST be hardened, vulnerability scanned, minimally provisioned, and regularly rebuilt. Production images MUST NOT include compilers, debugging tools, sample credentials, or unnecessary remote administration services unless justified.
- Kubernetes clusters MUST use RBAC, namespace/workload isolation, encrypted secrets at rest, admission controls, image provenance/scanning, network policies for sensitive workloads, and restricted privileged containers. Host networking, host PID/IPC, broad hostPath mounts, and privileged mode require explicit exception.
- Managed databases MUST not be directly Internet-accessible unless the service architecture requires it and Security has approved the design. Administrative access SHOULD traverse private endpoints or controlled bastions.
- Backups for critical workloads MUST be encrypted, access-separated, tested through restoration exercises, and protected from routine deletion by compromised workload identities using immutable or logically isolated controls where feasible.
- TLS 1.3 is required for new Internet-facing services where client compatibility permits. TLS 1.2 is permitted only with approved cipher suites. SSLv2/v3, TLS 1.0, TLS 1.1, weak ciphers, and self-signed certificates for production public services are prohibited.

6. Operational Control Requirements

- Cloud Security Posture Management or equivalent continuous configuration assessment MUST monitor production and sensitive environments. Critical findings require immediate triage and tracked remediation.

- Central security teams MAY enforce preventive controls through service-control policies, Azure Policy, organization policies, admission controllers, or equivalent mechanisms. Workload teams MUST NOT bypass guardrails through alternate regions/accounts.
- Critical production services MUST maintain tested recovery objectives, documented dependencies, backup/restoration procedures, and region/zone resilience appropriate to business impact.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- Cloud asset inventory
- IaC repositories and pipeline logs
- CSPM findings
- Cloud audit logs
- Exception register
- Backup restoration test evidence
- Key and secret rotation records

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Security may automatically quarantine public storage, exposed administrative services, compromised keys, malicious compute, or resources violating critical guardrails. Repeated or intentional violations may result in suspension of cloud deployment rights, mandatory remediation, disciplinary action, supplier escalation, or service shutdown where necessary to protect the enterprise.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Cloud exceptions MUST specify affected resources, business impact, threat analysis, compensating controls, monitoring, owner, and expiration. Exceptions that expose management interfaces or sensitive data to the public Internet require CISO delegate approval and cannot be indefinite.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports cloud-service governance, access control, configuration, logging, vulnerability management, network security, backup, supplier, and change-management objectives.

Framework	Policy alignment
NIST CSF 2.0	GV.RM/GV.SC governance; ID.AM assets; PR.AA identity; PR.DS data security; PR.PS platform security; DE.CM monitoring; RS/RC incident and recovery outcomes.
GDPR	Articles 25, 28 and 32 apply when cloud workloads process personal data; international transfer requirements apply to relevant hosting/support access.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.